Author: Durga Sai Sri Ramireddy

Sandworm's Assault on Ukraine: APT Warfare Against Critical Infrastructure

1. Introduction:

Advanced Persistent Threats (APTs) are a form of sustained and sophisticated cyberattacks which are characterized by their targeted nature and persistence, which make them more effective and dangerous than the traditional cyberattacks that the organizations encounter daily. APTs are often backed by nation-states, these long-term campaigns target organizations with the goal of espionage, disruption or even destruction. There are many APTs that the organizations had to encounter but one of the most notorious APTs in modern history is Sandworm, operated by MUN 74455, a Russian military intelligence service. Sandworm gained its spotlight for orchestrating the first-ever cyberattack that caused a physical blackout- the 2015 power gird disruption in Ukraine and followed by a sophisticated assault in 2016. These attacks marked a turning point in the landscape of cybersecurity. Especially in the domain of critical infrastructure. This paper highlights the evolution of Sandworm's operations against Ukraine's power grid while analyzing how the group carried out its attacks and offers insights into how organizations can protect themselves against such advanced threats.

2. Background on Sandworm APT:

Sandworm also known as BlackEnergy, Iron Viking, Voodoo Bear is believed to operate under the unit 74455 of the GRU. The group came to attention in 2014 when the security researchers linked them to attacks targeting NATO, U.S. defense contractors and the Ukrainian government entities. Sandworm's campaigns have evolved into highly destructive operations such as NotPetya ransomware outbreak in 2017 and also the interference with the 2018 Winter Olympics in South Korea. Sandworm's tactics have included spear-phishing, zero-day vulnerabilities, custom malware, and deep knowledge of industrial control systems (ICS). However, their 2015 and 2016 attacks on Ukraine were considered historic for being the first-ever confirmed cyber operations to cause power outages through manipulation of industrial control systems that had a direct effect of the critical infrastructure.

3. The 2015 Ukrainian Power Grid Attack

3.1. Events Unfolded:

The first known blackout that Ukraine sustained due to an incident involving cyber warfare happened on December 23, 2015. Power was cut without warning for nearly six hours, affecting over 230,000 people in the regions of Ivano-Frankivsk and Chernivtsi, among others. Attackers infiltrated three energy distribution companies through the SCADA systems, remotely switching off electrical substations.

The group had been preparing for this attack for several months. The methodology began with sending spear-phishing emails to deliver a variant of the BlackEnergy3 malware. This enabled hackers to first penetrate the corporate networks of their target and then, afterwards, to propagate horizontally, steal user credentials, and finally access the operational technology (OT) environment. Having arrived at their final destination, on the day of the attack, with manual chain command over thirty substations, they performed, at the same time, a denial-of-service attack with the (DDoS) telephone system to obstruct customers from reporting the outage occurrences and run the KillDisk, a wiper malware, to disable the operator workstations (Lee et al.).

3.2. The effect of the attack:

A number of vulnerabilities facilitated the attackers' success. There was insufficient separation between the IT and OT networks, allowing malware to cross from the enterprise environment into critical control systems. In addition, the organizations were deficient in monitoring systems for unauthorized remote access or lateral movement. Moreover, the systems were based with legacy industrial protocols like Modbus and DNP3 which have no built-in authentication or encryption. Such conditions serve to allow very well-coordinated disruptions to be executed by attackers without raising flags.

4. The 2016 Attack and the Emergence of Industroyer:

4.1. Events Unfolded:

Yet again, hardly a year later, a blackout struck Ukraine on December 17, 2016, this time in the capital city of Kyiv. The attackers used Aurora, or CrashOverride, a new malware framework that was specifically made to talk to ICS protocols. The blackout lasted about an hour and affected an area in the northern district of Kyiv.

Industroyer had more sophistication than BlackEnergy. It was modular and under control of native ICS protocols IEC 101, IEC 104, and OPC DA, which is how substation equipment speaks. That gave malware a way to send valid control commands: the adversary could open circuit breakers directly. It also had a wiper module, ruining the systems after the operation in the way of recovery (Cherepanov and Lipovsky).

4.2. The effects of the attack:

The attack in 2016 highlights the continuous systemic weaknesses. Based on the learning made in 2015, the infrastructure was still based on unencrypted, unauthenticated protocols and was vulnerable to direct manipulation. The network defenders were incapable of monitoring or detecting any behavior abnormal on the protocol level. Also, forensic capabilities were limited, thereby hindering the identification of the full functioning malware until it was after the attack.

Amidst this confusion and disorder, the cyber and physical response teams were working independently of one another, which further slowed the recovery process.

5. The 2022 Power grid disruption

5.1. Events unfolded:

In October of 2022, the Russian state-sponsored hacking group Sandworm coordinated a cyber attack on a Ukrainian power plant that resulted in a temporary blackout coinciding with massive missile strikes on sensitive infrastructures throughout the country.

The operation began with access by Sandworm to the plant's operational technology (OT) environment through a hypervisor hosting a supervisory control and data acquisition (SCADA) system. Then, across multiple months, the attackers voyeurized activity in SCADA environments. October 10, they planted a malicious optical disc image-a.iso-bearing a native MicroSC ADA binary to trigger commands stalling circuit breakers and, thus, nullify the overall power distribution.

Two days later, on October 12, Sandworm executed a second attack with a version of CaddyWiper on the IT infrastructure of the plant. This wiper was seen to try and delete data and deny recovery efforts but not affect the hypervisor and the SCADA virtual machine.

5.2. The effects of the attack:

In October 2022, the cyberattack on Ukraine's power grid by Sandworm came at a time when the country was already enduring incessant missile attacks and a full-scale war. This attack was not merely to switch off the lights; it was to multiply chaos. For the first time since its earlier blackout campaigns, Sandworm was able to successfully coordinate the disruption of electricity via cyber means with physical bombings, which had an amplifying effect: the lights went out for just a little while in the targeted region, and that little while of blackout became part of a larger assault on daily life injecting more fear and uncertainty into the already traumatized civilians.

The suddenness of this attack increased the stakes even higher. Unlike their previous attack employing custom malware of Industroyer kind, this time Sandworm chose to do more with what was prevalent in the environment, living off the land. A legitimate MicroSCADA control binary was used to transmit malicious commands without a trace until it was too late. They had been inside the hypervisor hosting the SCADA system for weeks, if not months, evading detection, gathering intelligence on the network layout and control logics, and awaiting an appropriate moment for an attack. In the course of that attack, CaddyWiper was launched on the IT side and not for shutting down the system, but to eliminate recovery data and hinder response. This demonstrates that their plan involved a bit more than causing a blackout; it was to increase difficulty in recovering from one.

Although power was later restored and key systems survived, this attack exposed some very serious vulnerabilities. It reminded defenders that air gaps are no silver bullet: if the SCADA system host was compromised, the virtualized SCADA system itself could be attacked. Attackers, it seems, are ahead: no longer so reliant on tacky malware that can be their undoing, they are now able to melt between legitimate tools, catching advanced defenders sweating. The psychological damage was immense. Ukrainian infrastructure operators had to concede that after all the work they'd done to defend their country for years, their systems were still not safe and, perhaps worse, attackers were adapting faster than the defenders.

Consequences on European and American facilities were spurred by the attack, which forced emergency reviews in Europe and the U.S. Utilities came to realize similar OT vulnerabilities might exist in their own environments. CERTs and threat intel teams increased monitoring of similar behaviors, and discussions around critical infrastructure security gained heightened urgency. Sandworm's 2022 operation was not just a regional strike, but a global wake-up call that modern-day cyberwarfare does not need heavy payloads for massive disruption.

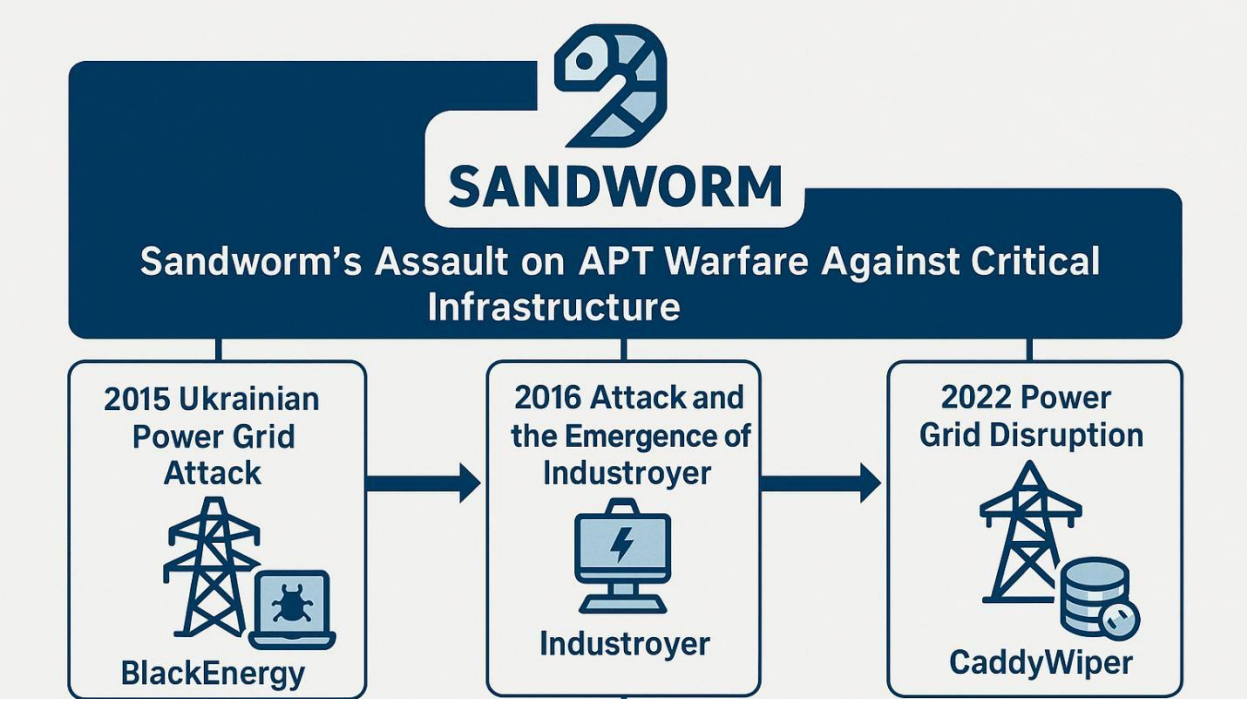

Fig 1.: Sandworm's Cyberattacks on Ukraine's Power Grid.

(Compiled and adapted based on multiple sources.)

6. Broader Impact and Strategic Significance:

The campaigns of Sandworm have successfully redefined global cybersecurity paradigms. The attacks of 2015 and 2016 forced a global reexamination of ICS security policies aimed at improvement of legacy systems and better segmentation. Not only were the Sandworm activities a force for launching public debate on the act of cyber-assaults classing under hybrid warfare by the US and EU, but such attempts at public debate also included their framing towards targeting civilian infrastructures in wartime conditions. It's the same with the 2022 attack attempt that proved that dangerous cyber-capabilities continue to pose threat potentials in modern warfare and reaffirmed the importance of international coordination and information sharing.

7. Lessons for Organizations Defending Against APTs

7.1 Infrastructure Hardening and Network Design:

Organizations maintaining any critical infrastructures should apply depth defense models separating IT and OT networks and controlling access physically as well. They should completely close all unused ports and services and regularly update firmware in ICS devices.

7.2 Monitoring and Detection:

SIEM and EDR security solutions can often reveal suspicious behaviors showing APT activity. Another example is that network traffic could be monitored significantly in reference to control protocols for ICS, such as IEC 104, to observe lateral movement at initial stages and be able to recognize early reconnaissance.

7.3. Monitoring and Detection:

Regularly conduct cyber attack simulations and tabletop exercises. Response plans must address ICS environments, including manual operation protocols and emergency shutoff procedures. Backup strategies should be in place to guarantee operational continuity in an attack.

7.4 Training and Intelligence Integration:

Cyber hygiene awareness among staff together with real-time threat intelligence sharing through ISACs will regularly be reducing the success rate associated with phishing and social engineering-the two major entry points for APTs.

8. Conclusion

The Sandworm APT group is becoming one of the most compelling and deadly examples of the effects of cyber warfare on real-world infrastructure. Their entire theater of operations-from the 2015 blacklist and 2016's blackouts to the more recent 2022 strike on Ukraine's power grid-demonstrate a chilling progression not just in technical capability but also in strategic coordination with kinetic warfare. Some of these attacks were not isolated digital pranks; they

disturbed the daily lives of people while exposing systemic weaknesses in industrial control systems and reshaped how nations discourse towards cybersecurity as part of their national defense stance. Sandworm stands out against this background due to its adaptability. Every attack had different techniques-either using custom malware like BlackEnergy and Industroyer to use more recent "living off the land" methods, taking advantage of legitimate software tools to fly below the radar. This proves to them that exploiting power grids or public infrastructures does not even need groundbreaking malware; it simply needs persistence, planning, and access to neglected overlooked entry points in poorly segmented environments. However, unlike criminal groups motivated by money, Sandworm is state-driven-cum-geopolitical disruption, psychological warfare, and strategic advantage.

But among all these threats, the clear message is that resilience has been possible and is possible. Ukraine, apart from being a major target, has developed ways of detecting and segmenting its networks, as well as intelligence sharing with allies. With the 2022 invasion effort state-by-state, it was quickly contained and restored even after hitting its mark for a time in the attack. Preparation works-and understanding the tactics, techniques, and procedures (TTPs) of threat actors is not just academic: it is vital. These attacks of Sandworm are not warnings for organizations involved in energy, transportation, water, or communication sectors. Rather, they are blueprints: what can happen where OT and IT security are considered separate silos-where known vulnerabilities go unpatched, and monitoring ceases at the firewall. But they also provide a roadmap: threatening hunting investments, behavioral monitoring in SCADA systems, and incident response plans that are tested.

Cyber threats by groups such as Sandworm are not going to disappear into thin air. In fact, they are becoming increasingly integrated into modern conflict. The only way out is proactive resistance, proactive resilience. For if Sandworm were to be the judge, while the war may not begin with missiles, it could easily begin with a mouse click in a network one always thought was invulnerable.

References:

1. "2015 Ukraine Power Grid Hack." *Wikipedia*, Wikimedia Foundation, last modified 1 Mar. 2025.

2. "2016 Ukraine Electric Power Attack, Campaign C0025." *MITRE ATT&CK*, MITRE Corporation, 31 Mar. 2023.

3. "2022 Ukraine Electric Power Attack, Campaign C0034." *MITRE ATT&CK*, MITRE Corporation, 27 Mar. 2024.

4. "How Sandworm, Russia's Elite Hackers, attacked a Small Mill Instead of Dam They Targeted." Le Monde, 17 Apr. 2024.

5. "ICC Probes Cyberattacks in Ukraine as Possible War Crimes, Sources Say." *Reuters*, 14 June 2024.

6. "Russia Attacked Ukraine's Power Grid at Least 66 Times to 'Freeze It Into Submission'." WIRED, 2023

7. "Russia's Sandworm Hackers Attempted a Third Blackout in Ukraine." WIRED, 13 Apr. 2022.

8. "Russian Hackers Used OT Attack to Disrupt Power in Ukraine Amid Mass Missile Strikes." SecurityWeek, 2023.

9. "Russian Hackers Used New Malware to Target Ukrainian Energy Sector." Axios, 31 Jan. 2023.

10. "Russian Military Hackers Targeted Ukrainian Power Company, Ukrainian Officials Say." CBS News, 2022.

11. "Sandworm (Hacker Group)." Wikipedia, Wikimedia Foundation, last modified 22 Apr. 2025.

12. "Ukraine Energy Facility Took Unique Sandworm Hit on Day of Missile Strikes, Report Says." The Record, Recorded Future News, 2023.